Activity 2 Bounded Hardening Sprint

Laurence Matthew B Manuel BSIT 3A PFEBSIT 002 Project 29 Week 15

Purpose and conclusion

I reviewed a self-created, inert weak-configuration fixture and then tested the real Week 14 baseline for matching risks. I did not deploy the weak fixture or insert vulnerabilities into the application. Five real protection gaps were reproduced before changes, prioritized by likelihood, impact, and exposure, fixed in the continuous application, and retested. The final regression passed without removing any earlier security control.

Fixture status and alternatives

`training-fixture-weak-config.yaml` is a labeled teaching example, not instructor-supplied configuration and not runtime input. It models plain HTTP, wildcard CORS, client-trusted roles, stack errors, unbounded pagination, unlimited retries, full payload logs, and inline secrets. The comparison fixture records the safer decisions.

Two approaches were considered. A static configuration review is quick and broad but cannot prove runtime behavior. An evidence-first sprint begins with failing executable tests, produces stronger proof, and costs more time across multiple layers. I selected the combined approach: use the inert fixture to rank patterns, but change source only when the actual baseline test supports a finding.

Ranked findings and hardening

Finding	Rank	Before	Change	After
Silent list truncation	P1	three records returned despite per_page=2; no metadata	validate page/per-page 1-100 and return total/has_more; show client notice	targeted test and API-09/API-10 pass
Unauthorized crypto work	P1	panel reached envelope processing and received 422	reject non-adviser or mismatched declared recipient before open	targeted test and API-11 return 403
Unsafe timeout advice	P1	every timeout advised form retry	same-key retry only with idempotency key; otherwise inspect status	two Flutter timeout tests pass
Malformed output classification	P2	non-JSON 200 looked like network outage	safe 502 protocol failure with correlation when available	Flutter protocol test passes
Missing browser API policies	P2	CSP absent	add CSP, Permissions-Policy, and HSTS	targeted test and API-12 pass

The client email and password limits were also aligned with the server. An initial use of visible counters broke 600-pixel-height test viewports, so the counters were removed while validators remained. This regression is retained rather than omitted.

Failure and recovery evidence

The controlled dependency probe to port 65530 failed within the two-second bound, emitted no sensitive payload, and was followed by a successful authorized API request. Worker timeout injection stopped after three attempts and routed to manual review. A simulated crash after tentative receipt insertion rolled back both receipt and attempt state; the next worker run delivered exactly once.

Interpretation

Observed facts. Five baseline protections failed, five fixes passed their original targeted tests, the layout regression was corrected, and final full suites passed. The final secret scan covered 244 candidate text files without an exact generated-secret or private-key match.

Reasoned conclusion. The sprint reduced concrete risks without broadening the product. Early authorization and idempotency-aware timeout guidance have the largest direct security/reliability effect because they prevent unnecessary protected work and unsafe repeated writes.

Recommendation. Add idempotency to action-item creation and choose per-user mutation rate limits only after Week 16 workload measurement. Confirm proxy header behavior and browser/assistive-technology combinations in the target nonproduction environment.

Limitations and acknowledgment

The sprint does not prove concurrency, performance, or production proxy behavior. The training fixture is self-created; no instructor weak service was supplied. AI assistance was reviewed against the retained failures, source diffs, and final test results.